

Unauthorised SaaS OAuth Application Integration response

Identity / SaaS · **High** severity · SOC IR Playbook

Incident type	OAuth Abuse - Unauthorised Third-Party App
Severity	High
Priority	High to Critical
Detection sources	CASB, SSPM, SaaS Admin Portals, SIEM, Threat Intelligence Feeds

Scenario

An employee or attacker grants a third-party application access to a corporate SaaS account using OAuth scopes (e.g., read email, access calendar, read/write files). These applications may exfiltrate data, impersonate users, or maintain persistent access without triggering standard credential or MFA alerts.

MITRE ATT&CK

T1098.003, T1528, T1550.001

Preparation

Restrict app consent policies Only allow OAuth consent for pre-approved or verified apps Monitor OAuth activity logs Use SIEM or SaaS security tools to track app authorisations and scopes Educate users About risks of authorising personal or unknown apps in corporate environments Integrate SSPM/CASP tools For visibility into authorised applications and risk scoring Apply conditional access policies To limit app connections from unmanaged devices

Detection & Analysis

Alert triggered Risky or unapproved OAuth app detected with elevated scopes (e.g., read mail, read drive, send messages) Identify user and application Who authorised it, what scopes were granted, and what app was used Analyse access logs Check if app accessed sensitive data or performed actions (e.g., sending emails, downloading files) Review app metadata Reputation, risk score, domain registration, previous threat reports

Containment

Revoke app access immediately Via admin portal (e.g., Azure AD, Google Workspace, Slack admin) Suspend impacted user account If malicious behaviour or data leakage is confirmed Block app domain or API endpoints Via firewall, CASB, or DNS filter to prevent callback connections Notify user and security team Initiate internal investigation and containment measures

Eradication

Remove residual access tokens Revoke all tokens granted to the app and refresh user sessions Rotate credentials and MFA If impersonation or token theft is suspected Conduct full data access review Determine what the app had access to and if data was exfiltrated Update OAuth policy Add the app to a blocklist or blacklist category in SSPM or CASB

Recovery

Reinstate user access with monitoring Ensure user awareness and endpoint clean-up if malware is linked Apply stricter app review process Require internal approval for all new app integrations Monitor for recurrence Create detections for similar app authorisation patterns or behaviours Validate SaaS logs and alerts Ensure full visibility of high-risk OAuth events

Lessons Learned & Reporting

Complete root cause analysis Why was the app authorised? Was it phishing, ignorance, or bypassed control?
Improve user training On secure SaaS usage and application access warnings Strengthen OAuth governance
Integrate SSPM and automate risk-based app approval/revocation Document the incident For compliance, audit trails, and policy updates Notify affected parties or regulators If customer data or sensitive records were accessed

Tools typically involved

SSPM/CASP (e.g., AppOmni, Obsidian, Microsoft Defender for Cloud Apps); SaaS Admin Portals (e.g., Azure AD, Google Admin Console, Slack Admin); SIEM (e.g., Sentinel, Splunk); Threat Intelligence (for app risk scoring and reputation); SOAR (to automate detection and revocation); Endpoint Security (to ensure token origin is clean)

Success metrics (SLA targets)

App Revocation Time <15 minutes from detection User Notification & Session Reset <30 minutes Full App Audit & RCA Completion Within 48 hours OAuth Policy Update Within 3 business days User Awareness Training Completion 100% within 5 business days